

Zero Trust Fundamentals

From Concept to Action



Speakers

Rev. John Maclean
Minister, Fisherman



/in/  /in/kentagerlund/
@AndreaS  @agerlund
Andreas.Sobczyk@twoday.com  Kent.agerlund@twoday.com



Kent Agerlund
Global Principal Architect
twoday
Microsoft Regional Director



Can't see our slides? Can't hear? Need to repeat the question? Call us out!



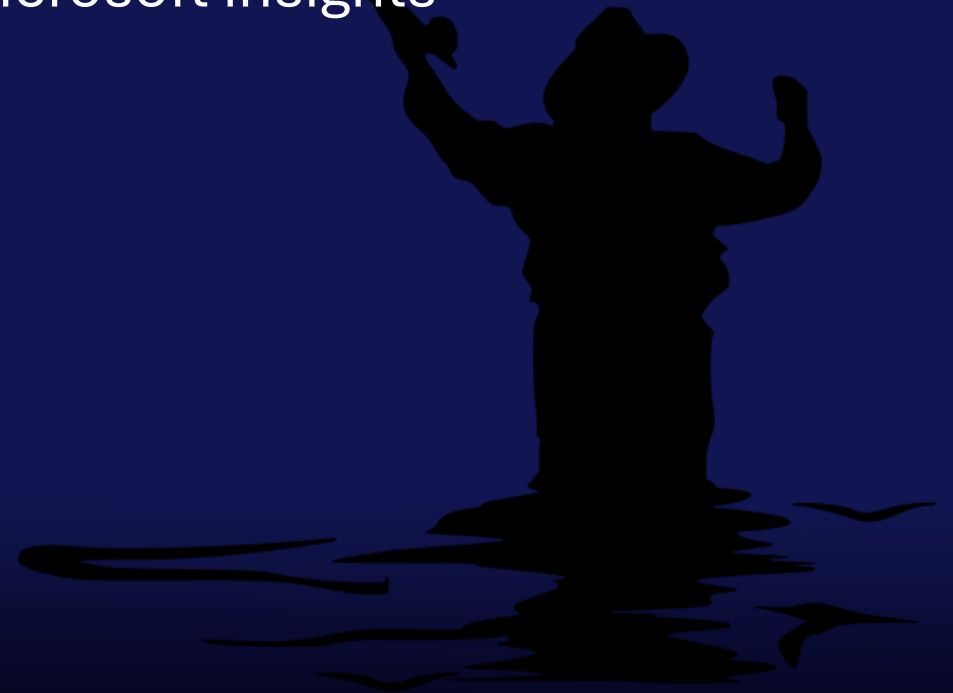
Session Takeaways #1 – Zero Trust

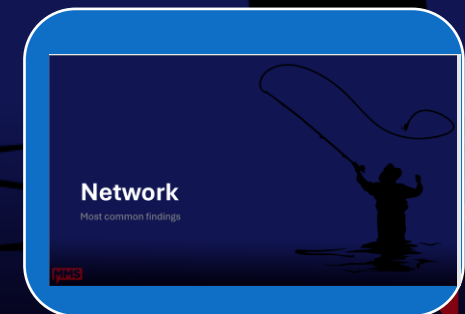
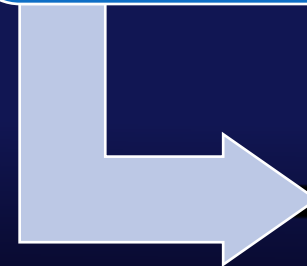
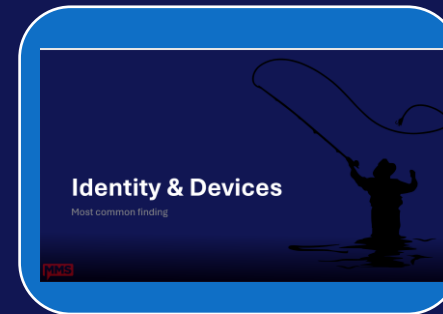
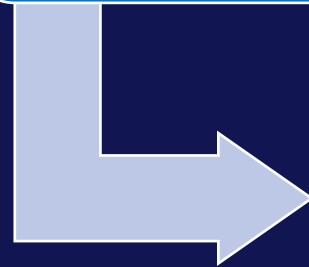
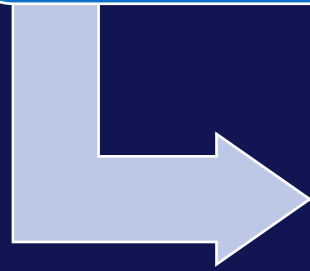
- ♦ **Goal:** Understand the fundamental principles of Zero Trust and their critical importance and Establish a prioritized roadmap for your Zero Trust implementation journey.
- ♦ **Headache:** Time and leadership commitment
- ♦ **Topics:** Zero Trust Framework, identity protection, device protection, data protection, network protection & app protection



Session Takeaways #2 – The assessment

- ♦ **Goal:** Enable you to execute an As-Is analysis to design your future (To-Be) security architecture.
- ♦ **Headache:** Getting started
- ♦ **Topics:** Existing frameworks, custom coding, Microsoft insights





Introduction

With a little description here



Your Zero Trust Homework (starts tomorrow)

♦ 1. Run the Zero Trust Assessment Tool

- ♦ Install → run → open the HTML
- ♦ Look at the red and orange items
- ♦ *Don't argue the about findings — start the conversations*

♦ 2. Show the report to someone outside your silo

- ♦ Entra Admin → show it to Intune Admin
- ♦ Intune admin → show it to the Security admins
- ♦ Security admin → show it to Purview Admin
- ♦ Purwin Admin → show it to hmmm you don't exist

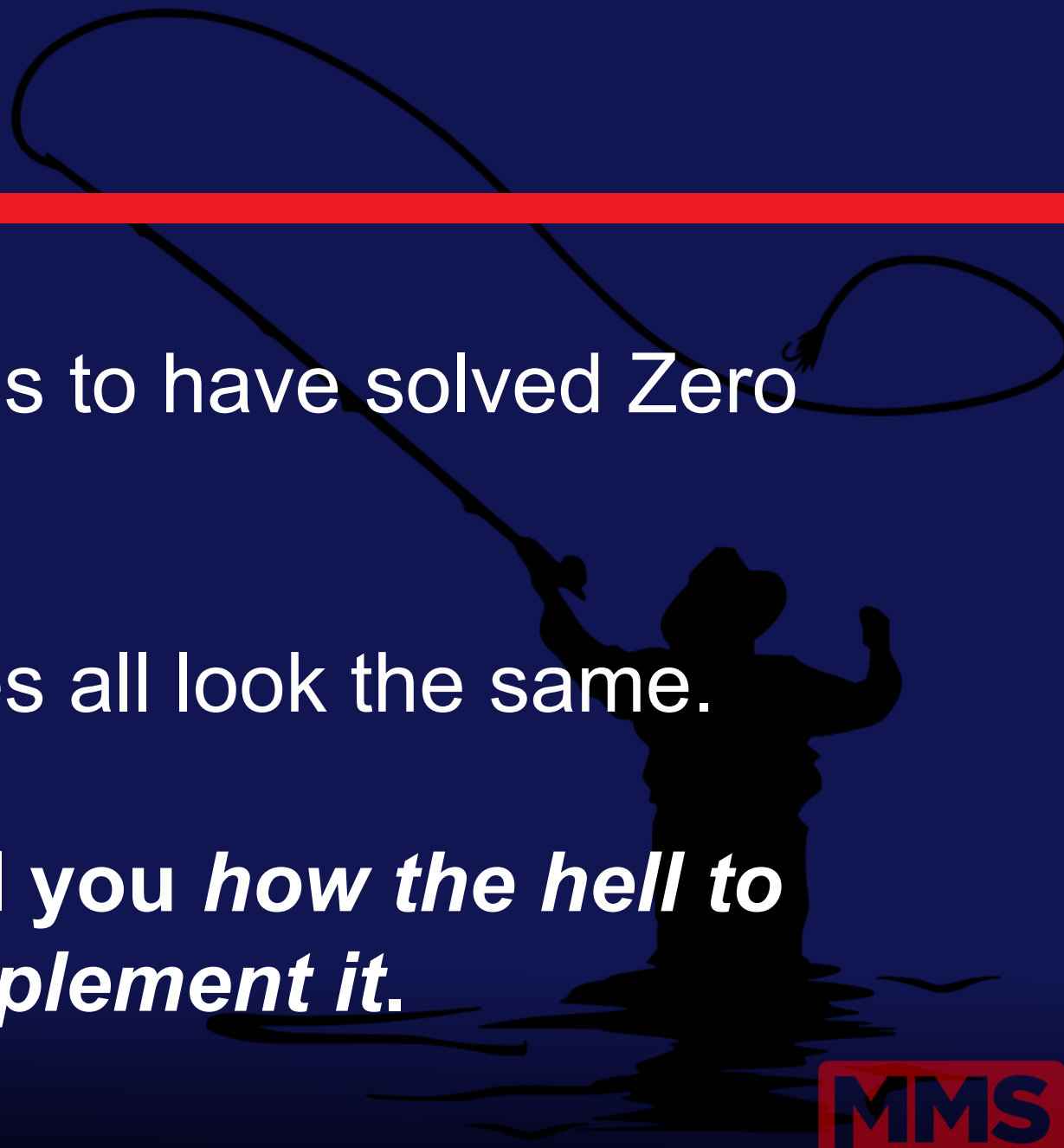
♦ 3. Take a step back and *think strategically*

- ♦ Get a sponsor
- ♦ Create a roadmap
- ♦ Where are the quick wins?
- ♦ Understand what is most important for your organization
- ♦ Read, share and discuss the Microsoft Digital Defense Report 2025

♦ 4. Pick ONE fix each - and help each other deliver it

- ♦ Examples:
 - ♦ Fix one dangerous device configuration gap
 - ♦ Move one ASR rule from Audit to Block
 - ♦ Clean up one unused admin role assignment

The fairy tale

A silhouette of a cowboy on a horse, herding a bull. The cowboy is holding a lasso that is looped in the air. The scene is set against a dark blue background with a red horizontal bar across the top.

Yes, every vendor claims to have solved Zero Trust.

Yes, the marketing slides all look the same.

No, none of them tell you *how the hell to actually implement it.*

.. But the reality is

Token theft from phishing is everywhere.

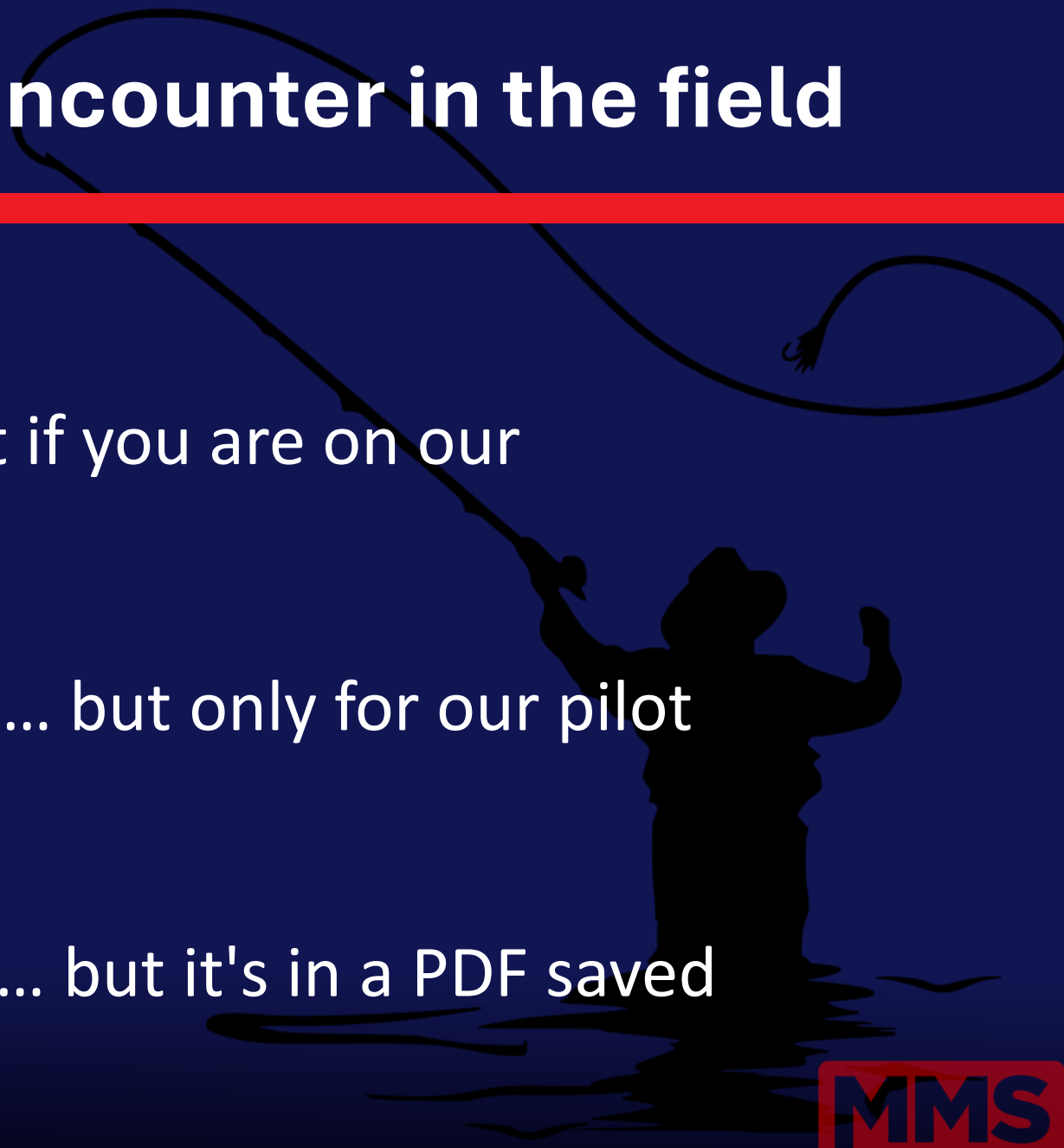
Device trust is often implicit

Data is leaking because people paste confidential content into ChatGPT.

And attackers don't care about your slide deck maturity model!



The real problems we encounter in the field

A silhouette of a cowboy wearing a hat and boots, standing in a field and swinging a lasso. The lasso is in mid-air, forming a large loop. The cowboy is positioned on the right side of the frame, facing left. The background is a solid dark blue.

Identity is a mess:

- "Yes, we have MFA... but not if you are on our location"

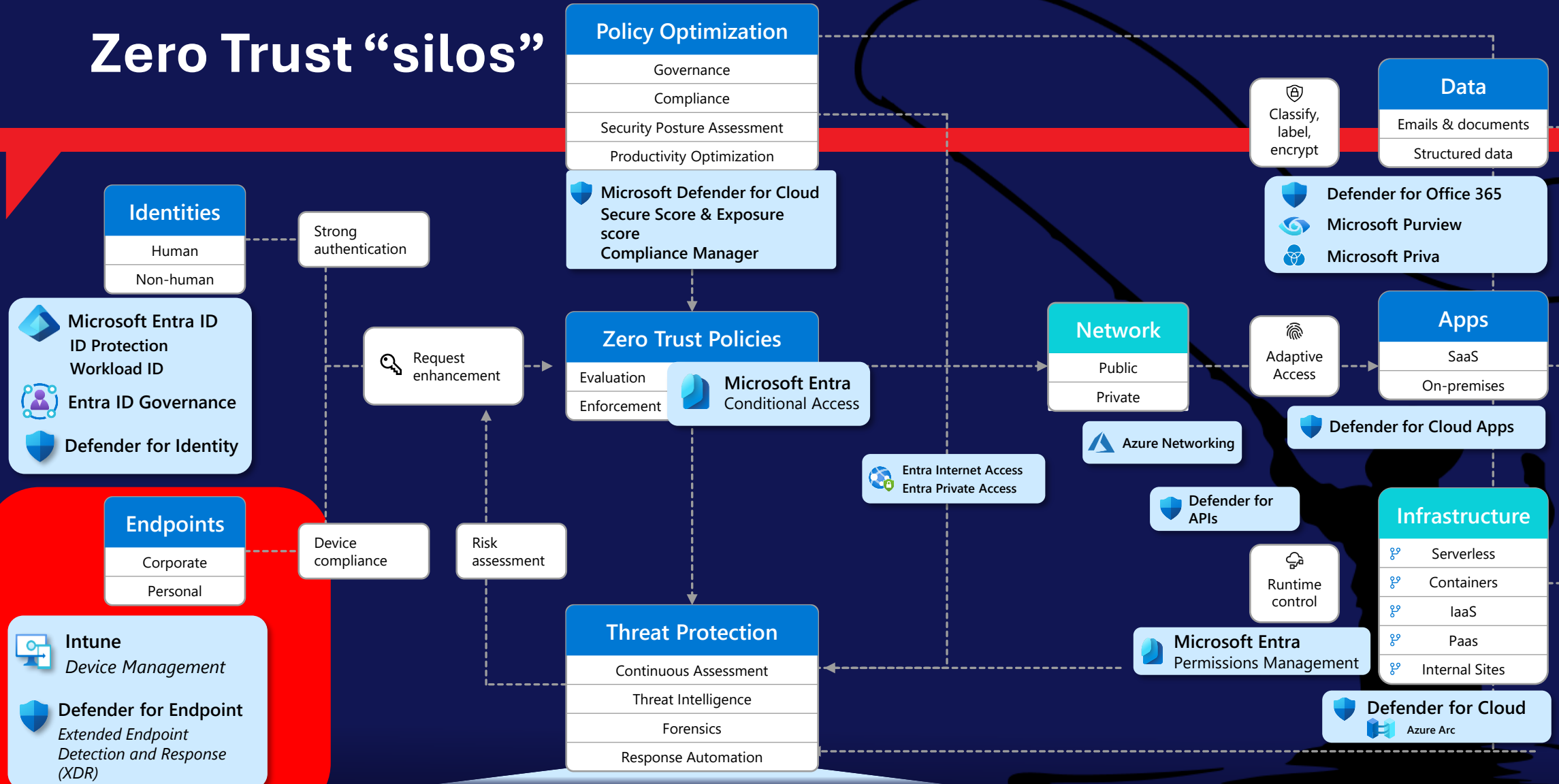
Device posture:

- "Yes, we require compliance... but only for our pilot devices in IT."

Data maturity:

- "We have data classification... but it's in a PDF saved on SharePoint."

Zero Trust “silos”



Microsoft Defender

Defender for Endpoint

Defender for Office 365

Defender for Identity

Defender for Cloud Apps

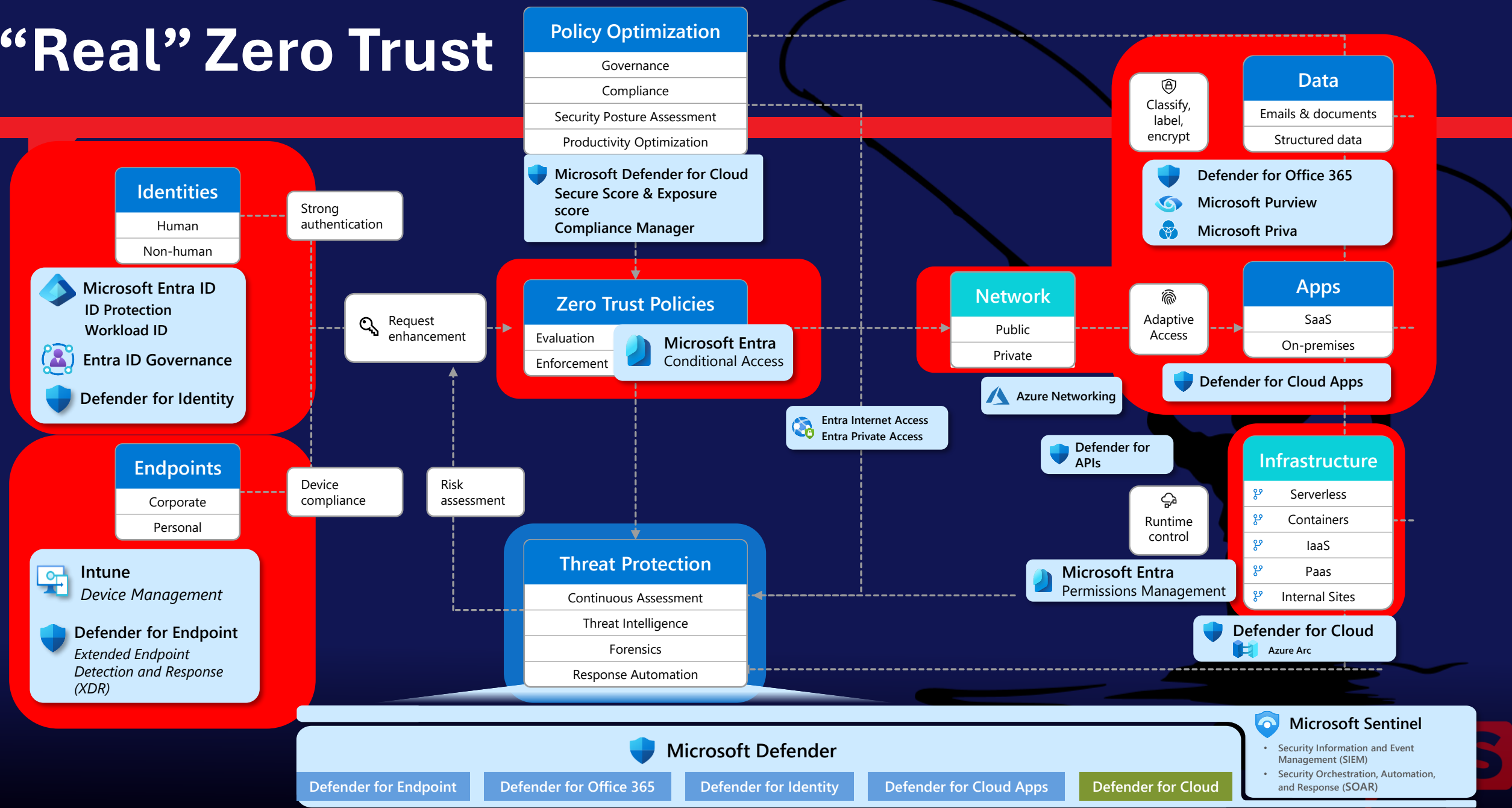
Defender for Cloud



Microsoft Sentinel

- Security Information and Event Management (SIEM)
- Security Orchestration, Automation, and Response (SOAR)

“Real” Zero Trust



Your attackers don't care about your Org Chart

- “Not my department” thinking = misconfigurations and blind spots
- Zero Trust requires shared telemetry across Identity, Device, and Data
- ◆ “Zero Trust dies the moment we say: *‘That’s not my job.’*”



Top 10 recommendations from this report

1. Manage cyber risk at the boardroom level

Treat cybersecurity as a business risk on par with financial or legal challenges. It is important that corporate boards and CEOs understand the security weaknesses of their organization. Track and report metrics like multifactor authentication (MFA) coverage, patch latency, incident counts, and incident response time to develop a comprehensive understanding of both your organization's potential vulnerabilities and its preparedness in the event of a cybersecurity incident.

2. Prioritize protecting identities

Since identity is the top attack vector, enforce phishing-resistant multifactor authentication across all accounts, including administrative accounts.

3. Invest in people, not just tools

Cybersecurity is a whole-of-organization effort. Find ways to upskill your workforce and consider making security part of performance reviews. Culture and readiness—not just technology—are primary factors in both an organization's defenses and its resilience.

4. Defend your perimeter

A third of attackers use crude tactics as the easy path into an organization's exposed footprint, often looking beyond what you deploy to the vendors and supply chain you trust, including perimeter web-facing assets (18%), external remote services (12%), and supply chains (3%). Knowing the full scope of your perimeter, auditing the accesses you grant to trusted partners, and patching any exposed attack surface forces attackers to work harder to be successful.

5. Know your weaknesses and pre-plan for breach

Combine knowledge of the organization's exposure footprint with organizational risk awareness to develop a proactive plan for responding to future breach. Tie security controls to business risks in terms the board can understand. Since a breach is a matter of when, not if, develop, test, and practice your incident response (IR) plan—including specific scenarios for ransomware attacks, which remain one of the most disruptive and costly threats to operations. How fast can you isolate a system or revoke credentials?

6. Map and monitor cloud assets

Since the cloud is now a primary target for adversaries, conduct an inventory on every cloud workload, application programming interface (API), and identity within the organization, and monitor for rogue virtual machines, misconfigurations, and unauthorized access. At the same time, work proactively to enforce app governance, conditional access policies, and continuous token monitoring.

7. Build and train for resiliency

If breaches are all but inevitable, resilience and recovery become key. Backups must be tested, isolated, and restorable, and organizations should have clean rebuild procedures for identity systems and cloud environments.

8. Participate in intelligence sharing

Cyber defense is a team, not individual, sport. By sharing and receiving real-time threat data with peers, industry groups, and government, we can make it harder for cyber adversaries to achieve their goals.

9. Prepare for regulatory changes

It's more important than ever for organizations to align with emerging laws like the European Union (EU) Cyber Resilience Act or United States (US) critical infrastructure mandates, which may require reporting cyber incidents within a certain timeframe or Secure by Design practices. These regulations reinforce the importance of timely incident reporting and stronger internal oversight of an organization's cybersecurity practices.

10. Start AI and quantum risk planning now

Stay ahead of emerging technologies. Understand both the benefits and risks of AI use within an organization and adjust your risk planning, attack surface exposure, and threat models appropriately. Prepare for a post-quantum cryptography (PQC) world by taking the time to inventory where encryption is used and create a plan to upgrade to modern standards as they evolve.

Key takeaways

What every leader needs to know about today's threat landscape

1. Phishing-resistant MFA is the gold standard for security

No matter how much the cyber threat landscape changes, multifactor authentication (MFA) still blocks over 99% of unauthorized access attempts, making it the single most important security measure an organization can implement. Phishing-resistance provides an even more secure solution.

[Read more on p23](#)

2. Adversaries are targeting identities that enable access to data

Government organizations, information technology (IT) companies, and research and academic institutions were the most impacted by cyber threats this year. Among other data they hold that might interest adversaries, these organizations store vast amounts of personally identifiable information (PII), whose theft enables future attacks. Accessing organizational data has become a primary objective for threat actors. Government, NGO, and academic entities using legacy systems or operating with small IT teams and limited incident response capabilities should prioritize securing data and identity-facing assets.

[Read more on p17](#)

3. Adversaries are using diverse—but well-known—initial access routes

Incident response investigations found that 28% of breaches were initiated through phishing or social engineering, 18% were via unpatched web assets, and 12% leveraged exposed remote services. Not only are adversaries heavily leveraging the ClickFix social engineering method to deliver malware this year, but threat actors are incorporating exploits for known vulnerabilities faster than ever.

[Read more on p13](#)

4. Most attacks are for money, not espionage

More than half of cyberattacks with known motives had financial objectives such as extortion or ransom, while only 4% were motivated solely by espionage.

[Read more on p11](#)

5. Data exfiltration is the norm

Regardless of adversary motivations, accessing organizational data is now a primary goal for attacks. In the past year, we observed data collection in 80% of reactive engagements.

[Read more on p29](#)

6. Workload identities are under threat

As organizations implement phishing-resistant MFA and conditional access policies, adversaries are pivoting to targeting identities and elevated privileges granted to service-to-service workloads like apps, services, and scripts that access cloud resources because service-based workloads are often implemented with elevated privileges but weak security controls.

[Read more on p17](#)

7. Adversaries are conducting destructive attacks in the cloud

We have seen an 87% increase in campaigns aimed at disrupting Azure cloud customer environments through destructive actions such as ransomware or mass deletion. Additionally, over 40% of ransomware attacks now involve hybrid components.

[Read more on p41](#)

8. Adversaries are already using AI as a multiplier

Adversaries have begun implementing AI across a range of malicious activities, including for automated vulnerability discovery or phishing campaigns, malware or deepfake generation, data analysis, and to craft highly convincing fraudulent messages.

[Read more on p52](#)

9. Using AI can be both a benefit and a vulnerability

AI is driving rapid, substantial change. While it offers many benefits for organizations, particularly in cyber defense, AI can be attacked as well. As organizations implement the strengths of AI, they should also manage the weaknesses and potential exposure of sensitive data by protecting against threats like prompt injection, malicious tool invocation, and training data poisoning.

[Read more on p52](#)

10. Quantum computing could challenge cybersecurity

Quantum computing has vast economic potential, but if used by malicious actors, it could threaten the encryption of sensitive data.

[Read more on p57](#)

From fancy PowerPoint to field experience

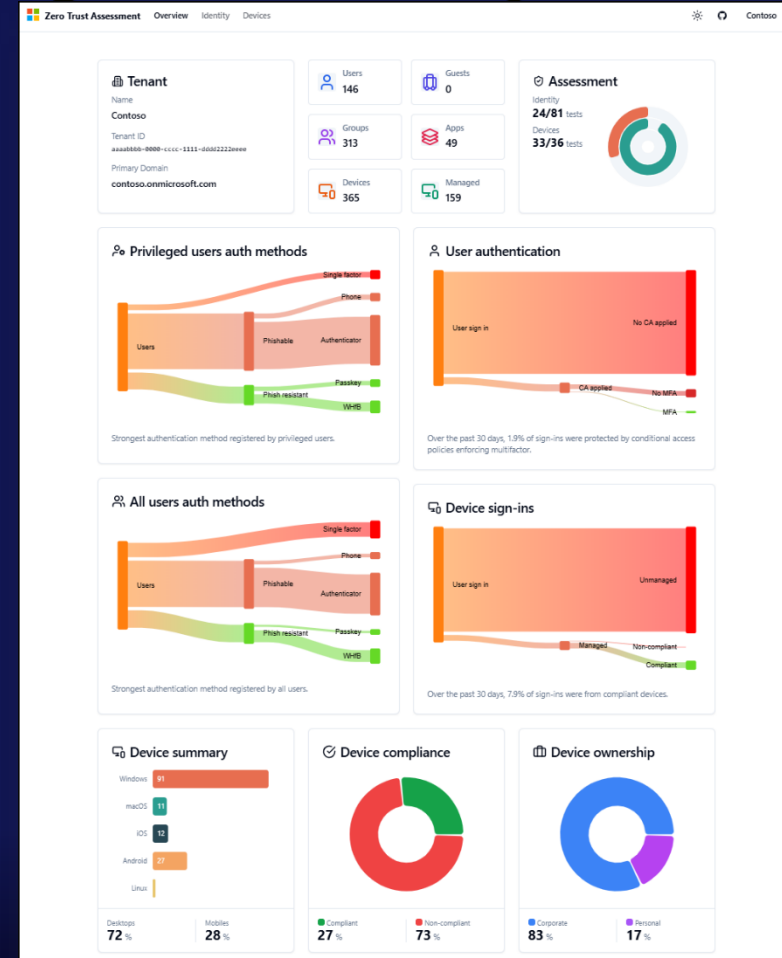
Let's see some action



A solution?

The New Microsoft Zero Trust Assessment Tool

- It scans your tenant using Graph with read-only permissions.
- It produces a beautiful HTML report with actionable findings.
- It tells you what's broken before attackers tell you.



Demo

How It Works

Here's a quick summary of the steps for you to run the tool. Check [our documentation](#) for full details.

First, you install the ZeroTrustAssessment PowerShell module.

```
1 | Install-Module ZeroTrustAssessment -Scope CurrentUser
```

Then, you connect to Microsoft Graph and to Azure by signing into your tenant.

```
1 | Connect-ZtAssessment
```

After that, you run a single command to kick off the data gathering. Depending on the size of your tenant, this might take several hours.

```
1 | Invoke-ZtAssessment
```

After the assessment is complete, the tool will display the assessment results report. A sample report of the assessment can be viewed at aka.ms/zerotrust/demo.

The tool uses read-only permissions to download the tenant configuration, and it runs the analysis locally on your computer. We recommend you treat the data and artifacts it creates as highly sensitive organization security data.

Getting operational

Zero Trust Workshop

Pillar: Identity Devices Data Network Infrastructure Security Operations AI

?

Actions

Check the [workshop delivery guide](#) for more details

Legend: Implementation Effort High Medium Low User Impact High Medium Low License Required license Notes Has notes Cross-Pillar Spans multiple pillars

Filter Areas

Map and Assess AI Risk

Gain AI Visibility

AI Security Posture Assessment

Registry Readiness

Not Reviewed

Not Started

In Planning

Planned

In Progress

Completed

Blocked

First Party Other

Third Party

Will Not Pursue

MS Roadmap

Follow Up

Not Applicable

Not Reviewed

View details

First

Then

Next

Gain AI Visibility

Assess AI risk with Microsoft Security Dashboard for AI

COMPLETED

Discover and inventory existing agents in Agent 365 Registry

IN PROGRESS

Configure Global Secure Access dashboard for generative AI app

IN PROGRESS

Configure Microsoft Defender for Cloud Apps GenAI app discovery

NOT REVIEWED

Enable Microsoft Purview Audit for AI interactions

NOT REVIEWED

Deploy DSPM for AI overview and get started prerequisites

NOT REVIEWED

Enable Microsoft Defender for Cloud AI security posture management

NOT REVIEWED

Enable diagnostic logging for AI services and agents

NOT REVIEWED

AI Security Posture Assessment

Configure Privileged Roles to manage AI

NOT REVIEWED

Review AI agent, model, and app inventory

NOT REVIEWED

Review and prioritize AI risk findings

NOT REVIEWED

Configure recommendation delegation workflows

NOT REVIEWED

Establish ongoing monitoring and remediation

NOT REVIEWED

Registry Readiness

Require users to use Microsoft Entra ID auth to interact with agents

NOT REVIEWED

Require users to register agents in Agent 365 Registry before use

NOT REVIEWED

Configure Copilot Studio data policies for agent capabilities

NOT REVIEWED

Configure agent publishing and deployment controls

NOT REVIEWED

Create and apply governance templates for agent publishing and activation

NOT REVIEWED

Define agent collection taxonomy

NOT REVIEWED

Configure Agent 365 access and sharing policies

NOT REVIEWED

Configure Microsoft Defender for Cloud Apps GenAI app discovery

Notes: Add notes about this task...

Save

0/1000

MMS

DEMO

The Assessment

Running the Zero Trust Assessment



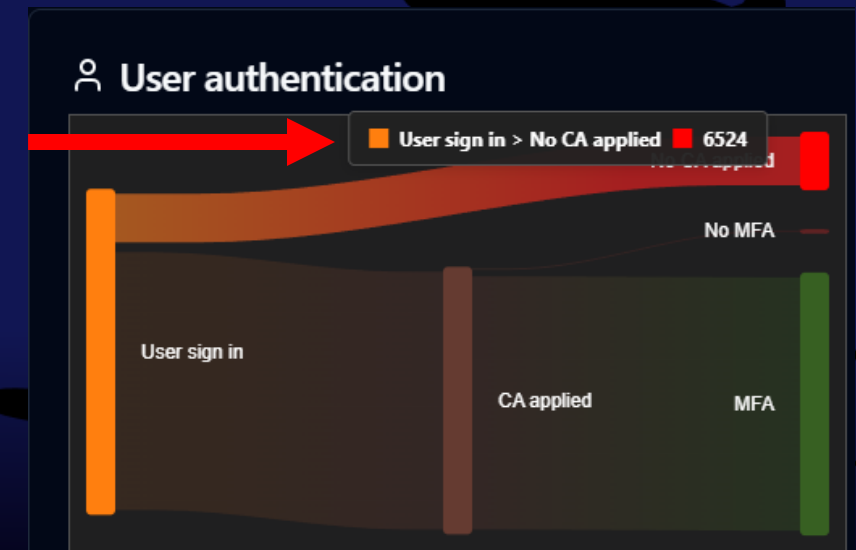
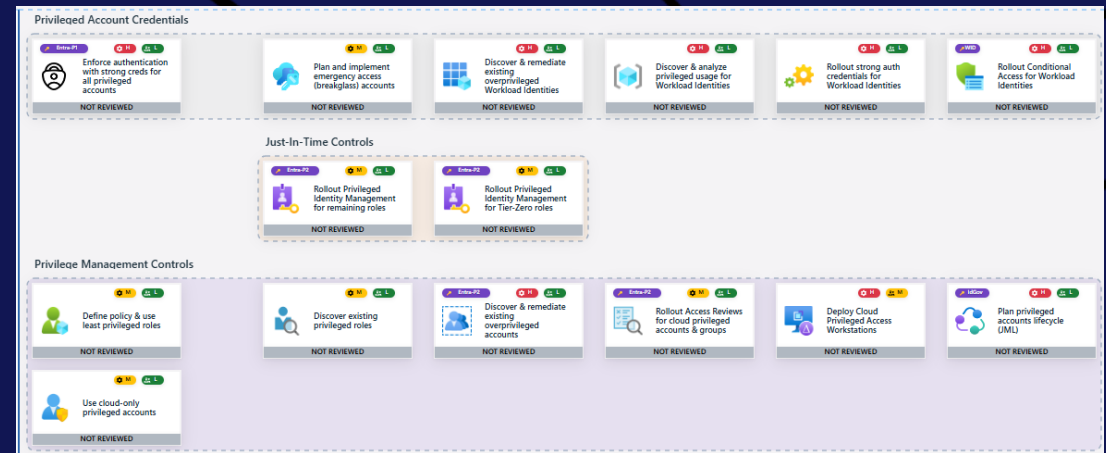
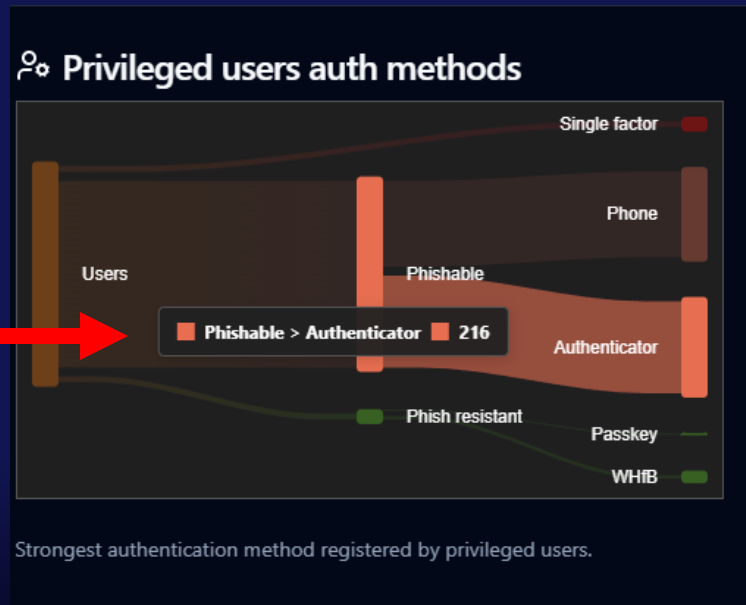
Identity & Devices

Most common findings



Identity

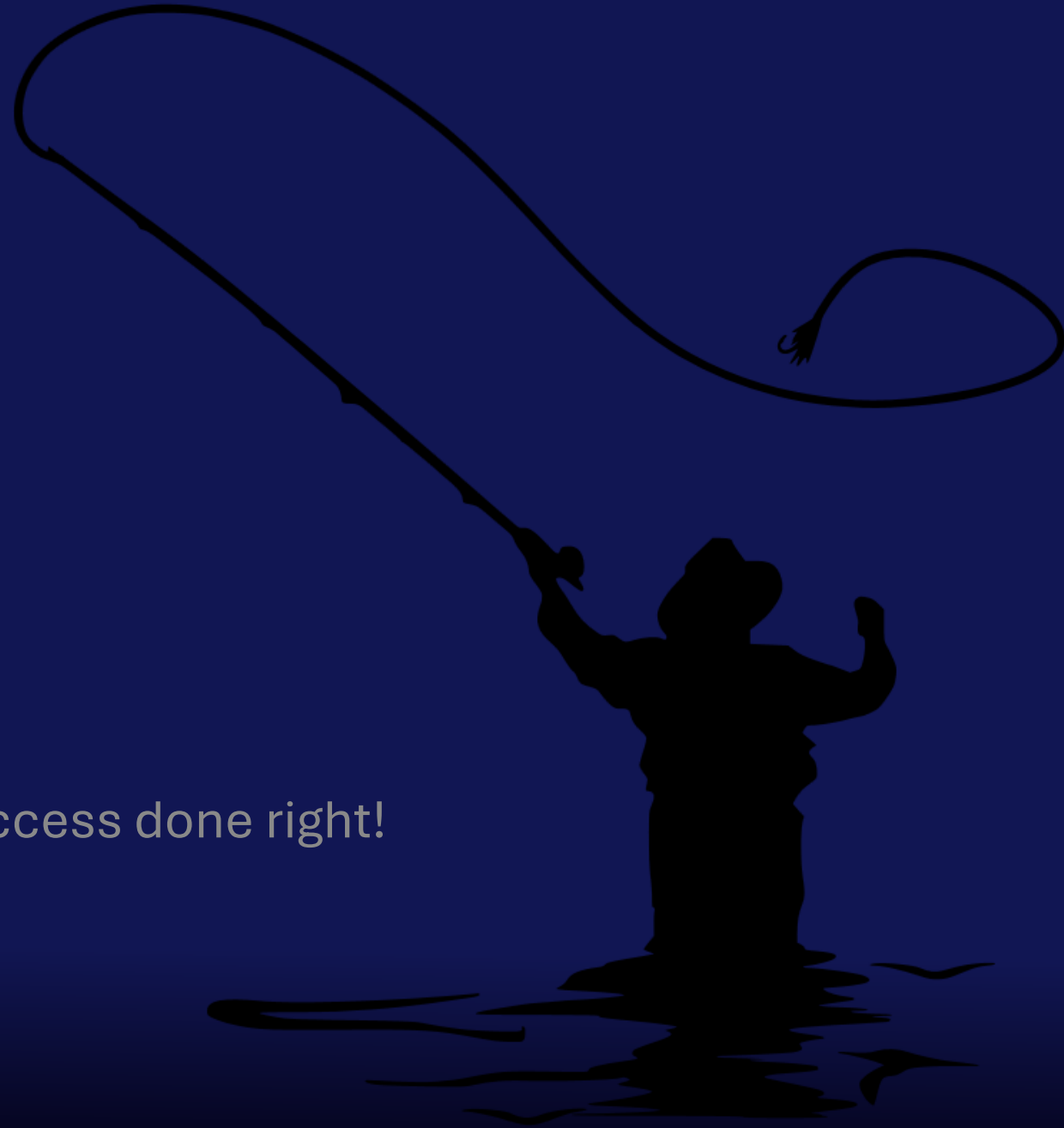
- ◆ Privileged Accounts
- ◆ Conditional Access done right
- ◆ MFA keeps evolving



DEMO

Demo

PIM & Conditional Access done right!



Devices

- ♦ Audit = Good intentions
- ♦ Hackers loves good intentions any day of the week
- ♦ Policy Sprawl

Browser x OS Security Baseline Coverage			
Copy	Excel	CSV	PDF
Show 15 rows	Search Builder	Switch to ScrollX	
Browser	OS Platform	Device Count	Security Baseline
Apple Safari	iOS	763	No
Apple Safari	macOS	8	Yes
Brave Browser	iOS	10	No
Brave Browser	Windows	12	Yes
Google Chrome	iOS	241	No
Google Chrome	unknown	1	No
Google Chrome	Windows	1392	Yes
Microsoft Edge	iOS	393	No
Microsoft Edge	macOS	45	Yes
Microsoft Edge	unknown	1	No
Microsoft Edge	Windows	27713	Yes
Mozilla Firefox	iOS	14	No
Mozilla Firefox	Windows	408	Yes
Opera	iOS	3	No
Opera	Windows	77	Yes

Showing 1 to 15 of 15 entries

Zero Trust Assessment

Overview

Identity

Devices

Network

Data

Search by name...

Risk:

High

Medium

Low

Status:

Passed

Failed

Filter by SPI Pillar:

Protect identities and secrets

Protect networks

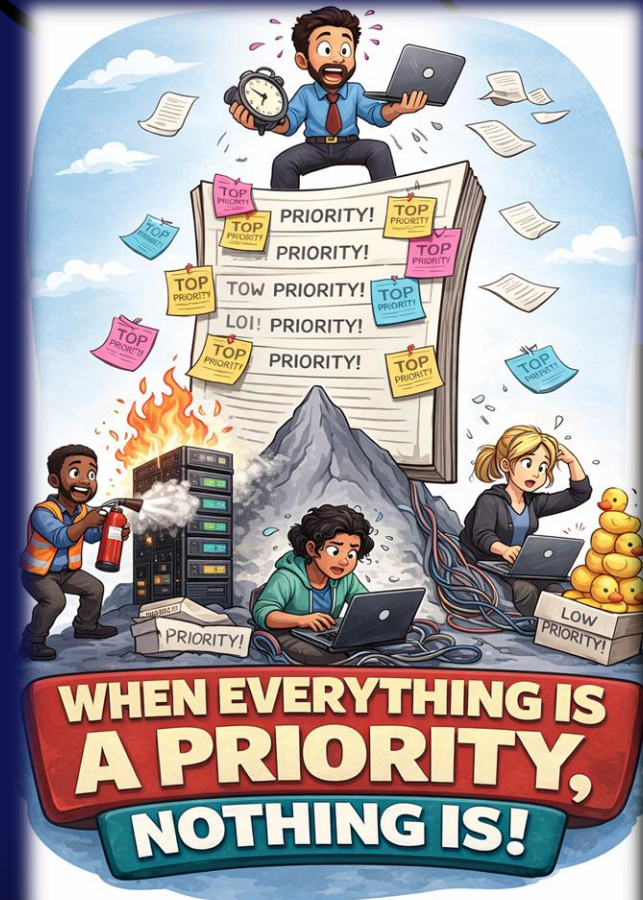
Protect tenants and isolate production systems

Showing 33 of 33 tests

Name ↑↓	Category ↑↓	Min. License ↑↓	User Impact ↑↓	Imp. Effort ↑↓	Risk ↑↓	Status ↑↓
Compliance policies protect fully managed and corporate-owned Android devices	Tenant	Intune	Medium	Low	↑ High	Failed
Authentication on Windows uses Windows Hello for Business	Device	Intune	Medium	Medium	↑ High	Failed
Defender Antivirus policies protect macOS devices from malware	Device	Intune	Low	Low	↑ High	Failed
Local administrator credentials on macOS are protected during enrollment by macOS LAPS	Device	Intune	Low	Low	↑ High	Failed
Compliance policies protect personally owned Android devices	Tenant	Intune	Medium	Low	↑ High	Failed
Attack Surface Reduction rules are applied to Windows devices to prevent exploitation of vulnerable system components	Device	Intune	Medium	Medium	↑ High	Failed
Local administrator credentials on Windows are protected by Windows LAPS	Device	Intune	Low	Low	↑ High	Failed
Data on Android is protected by app protection policies	Data	Intune	High	Low	↑ High	Failed

Getting actionable

- ◆ Prioritize
 - ◆ Impact
 - ◆ Work effort
- ◆ License requirements
- ◆ Service dependencies
 - ◆ Defender
 - ◆ Entra
 - ◆ Purview
 - ◆ Autopatch
 - ◆ PIM
 - ◆ Defender for CloudApps
 - ◆ And the list goes on



DEMO

Demo

Device Security

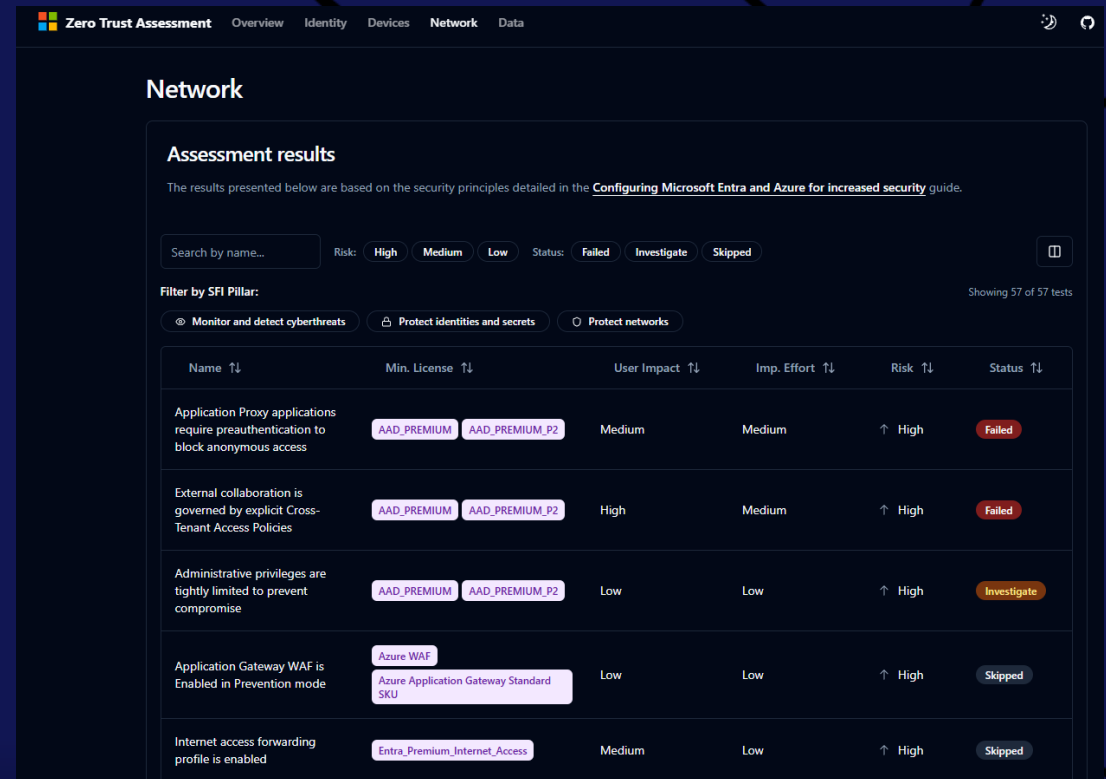


Network

Most common findings



Network



The screenshot displays the 'Network' section of the Zero Trust Assessment interface. It features a navigation bar with tabs for Overview, Identity, Devices, Network, and Data. The main content area is titled 'Network' and contains an 'Assessment results' section. This section includes a search bar, risk filters (High, Medium, Low), and status filters (Failed, Investigate, Skipped). Below these filters, there is a 'Filter by SFI Pillar' section with three options: Monitor and detect cyberthreats, Protect identities and secrets, and Protect networks. The main table lists five assessment items with columns for Name, Min. License, User Impact, Imp. Effort, Risk, and Status. The items are: Application Proxy applications require preauthentication to block anonymous access (Failed), External collaboration is governed by explicit Cross-Tenant Access Policies (Failed), Administrative privileges are tightly limited to prevent compromise (Investigate), Application Gateway WAF is Enabled in Prevention mode (Skipped), and Internet access forwarding profile is enabled (Skipped).

Name	Min. License	User Impact	Imp. Effort	Risk	Status
Application Proxy applications require preauthentication to block anonymous access	AAD_PREMIUM, AAD_PREMIUM_P2	Medium	Medium	High	Failed
External collaboration is governed by explicit Cross-Tenant Access Policies	AAD_PREMIUM, AAD_PREMIUM_P2	High	Medium	High	Failed
Administrative privileges are tightly limited to prevent compromise	AAD_PREMIUM, AAD_PREMIUM_P2	Low	Low	High	Investigate
Application Gateway WAF is Enabled in Prevention mode	Azure WAF, Azure Application Gateway Standard SKU	Low	Low	High	Skipped
Internet access forwarding profile is enabled	Entra_Premium_Internet_Access	Medium	Low	High	Skipped

DEMO

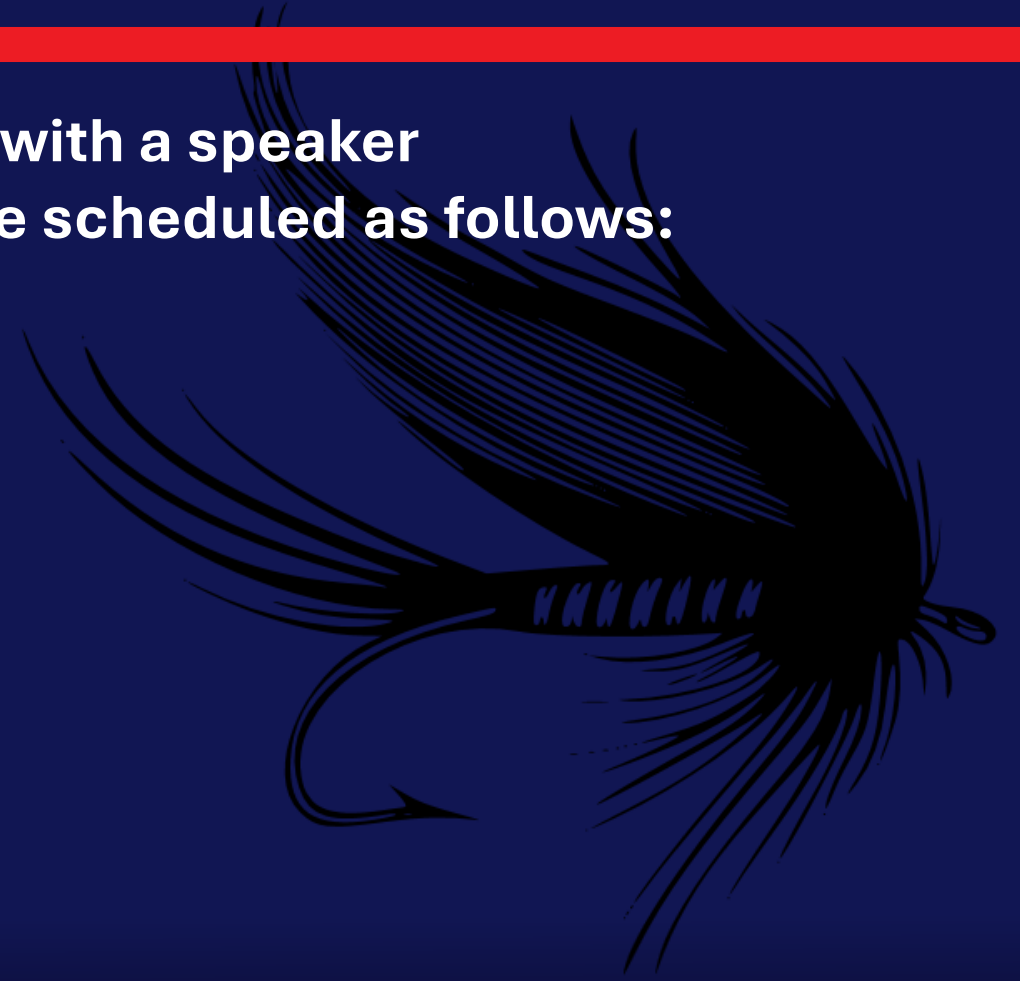
Demo

Network Security



Fishing Sessions

Be sure to find Wally and sign up for 1:1 time with a speaker
If you'd like to "catch" us for a session, we are scheduled as follows:



Don't forget to leave feedback for your speakers!

SAVE THE DATES

Oct 25-28, 2026



May 2-6, 2027



Oct 10-13, 2027



Extended Q&A



Recast



ninjaOne®



numecent®

